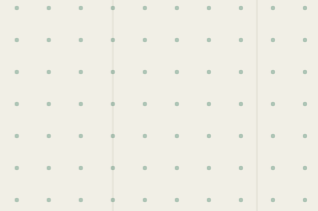




hugs id



— TECHNICAL REFERENCE · V 1 . 1

HUGS ID™

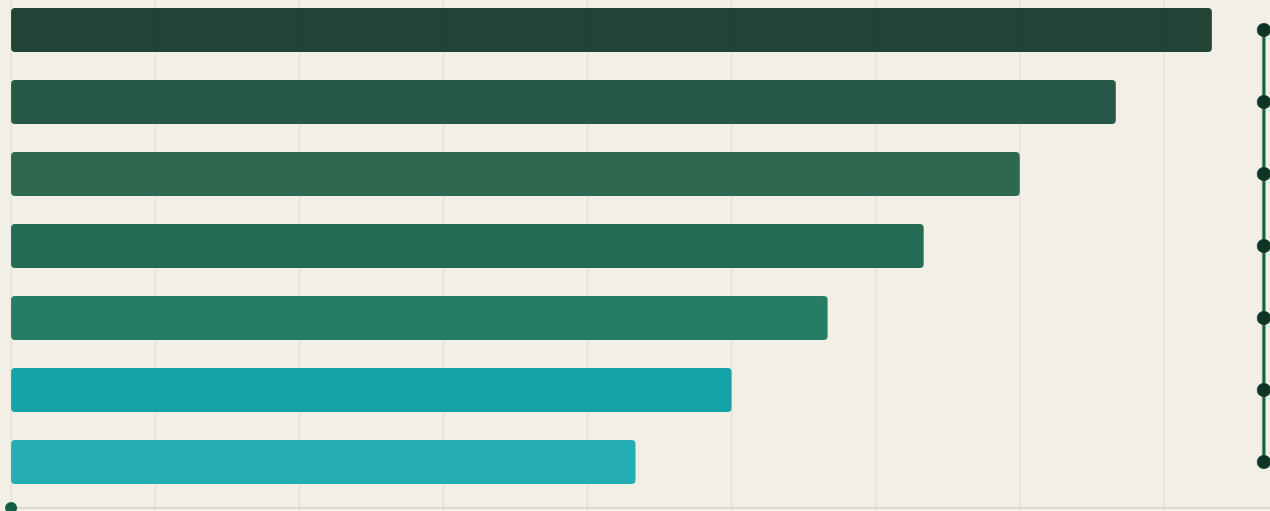
Technical Specification

The Canonical Identity and Governance Framework for the AI Era

Version 1.1 · Public Working Draft

4 August 2026 — Publisher: HUGS ID™

Canonical reference: hugsid.com · Documentation portal: learn.xpguess.com



Status of This Document

This document is the authoritative technical reference for the HUGS ID™ platform. It defines the architecture, identity model, governance framework, consent framework, AI permission model, trust framework, trust chain, and application programming interfaces of the HUGS ID standard.

Document	HUGS ID™ Technical Specification
Version	1.1 (semantic versioning applies to all schemas defined herein)
Status	Public Working Draft — open for review and implementation feedback
Publication date	4 August 2026
Publisher	HUGS ID™
Canonical reference	hugsid.com
Documentation portal	learn.xpguess.com
Intended audience	Developers, researchers, institutions, governing bodies, AI systems
Supersedes	v1.0 Public Working Draft (4 August 2026)
Companion document	HUGS ID Security Review and Remediation Annex v1.0

Version 1.1 incorporates the findings of an independent security and architecture review of v1.0. The review identified no fundamental architectural failure; its findings concerned missing cryptographic mechanisms and enforcement requirements, which this revision adopts as normative requirements (see Section 12, Security Review Disposition). The full review is retained in the companion annex.

Changes in v1.1

- Cryptographically signed Authority Chain objects with attenuation, expiry, and signed revocation (Section 5.3).
- Key-bound identities, signed verification and governance objects, and proof-of-possession requirements (Sections 4.1, 4.5).
- Guardian Relationship Verification for consents involving minors (Section 6.5).
- Enforced human review, notification, and contestation for decide-class AI actions; cryptographically bound synthetic-media provenance (Sections 8.4, 8.5).
- Pairwise pseudonymous identifiers, sensitive-data protections, and erasure-compatible audit records (Sections 4.6, 6.6).
- Object-level API authorization, webhook delivery security, atomic fail-closed consent enforcement, and identifier entropy requirements (Sections 4.2, 10.2, 10.4–10.7).

Document Conventions

The key words MUST, MUST NOT, REQUIRED, SHALL, SHALL NOT, SHOULD, SHOULD NOT, RECOMMENDED, MAY, and OPTIONAL in this document are to be interpreted as described in RFC 2119 [1]. Requirement

identifiers take the form REQ-<section>-<number> and are stable across v1.x revisions. All timestamps are ISO 8601 / RFC 3339 UTC. All object schemas are version-controlled and published under the reserved namespace hugsid.com/schemas/v1.

Object names and field names appear in monospace-style lowercase snake_case when referenced in prose. Figures and tables are numbered sequentially within each section.

Table of Contents

1. Vision.....	3
1.1 Vision Statement	4
1.2 Objectives	5
1.3 Non-Goals	6
2. Problem Statement	7
2.1 The Fragmentation of Digital Identity.....	8
2.2 The AI Inflection Point	9
2.3 Design Principles	10
3. Architecture	11
3.1 Layered Architecture	12
3.2 Layer Responsibilities	13
3.3 Data Flow	14
3.4 Governed Domains.....	15
4. Identity Layer.....	16
4.1 The Canonical Identity Object	17
4.2 Identifier Scheme	18
4.3 Identity Types	19
4.4 Identity Lifecycle.....	20
4.5 Key Binding and Proof of Possession	21
4.6 Pairwise Pseudonymous Identifiers.....	22
5. Governance Layer	23
5.1 Governance Objects	24
5.2 Policy Model	25
5.3 Authority Chains.....	26
5.4 Institutional Roles.....	27

6. Consent Layer	28
6.1 The Consent Object	29
6.2 Purpose Taxonomy	30
6.3 Consent Lifecycle	31
6.4 Revocation	32
6.5 Guardian Relationship Verification	33
6.6 Sensitive Data and Erasure	34
7. Athlete Intelligence	35
7.1 Overview	36
7.2 Governed Data Classes	37
7.3 Use Cases	38
8. AI Permissions	39
8.1 AI Agent Identity	40
8.2 AI Permission Classes	41
8.3 Attribution Requirements	42
8.4 Enforced Human Review and Contestation	43
8.5 Synthetic Media Provenance	44
8.6 Prohibited Uses	45
9. Trust Framework	46
9.1 The Trust Score	47
9.2 Trust Levels	48
9.3 Verification Framework	49
9.4 Reputation Framework (Planned)	50
9.5 Regulatory Alignment and Trust Chain	51
10. APIs	52
10.1 Overview	53
10.2 Authentication and Authorization Scope	54
10.3 Core Resources	55
10.4 Status Codes	56
10.5 Events and Webhooks	57
10.6 Webhook Security	58
10.7 Atomicity and Fail-Closed Enforcement	59
11. Roadmap	60
11.1 Release Roadmap	61
11.2 Versioning Policy	62

11.3 Contributing	63
12. Security Review Disposition	64
12.1 Review Outcome	65
12.2 Prerequisites to Production Implementation	66
12.3 Remediation Mapping	67
13. References	68

1. Vision

1.1 Vision Statement

HUGS ID™ exists to create a globally interoperable identity and governance standard that allows every individual to manage the lifecycle of their verified digital identity, while enabling trusted collaboration between institutions and artificial intelligence systems.

Mission: To become the trusted identity, provenance, and digital trust layer for the AI era by connecting verified people with verified digital content through a secure, transparent, interoperable, and auditable trust chain.

Every person already has a digital identity. Very few people control it. HUGS ID separates identity from data ownership: rather than creating another database, it establishes a governance layer that determines how identity, permissions, provenance, consent, verification, and trust interact across independent systems.

1.2 Objectives

- G-1 Define a canonical, machine-readable identity object that any institution or AI system can resolve, verify, and reference unambiguously.
- G-2 Give individuals enforceable authority over how verified information about them is used, by whom, and for what purpose.
- G-3 Make every AI action attributable to an identity, an authorization, a purpose, and a governance policy.
- G-4 Integrate with existing institutional systems — sports federations, universities, government agencies, healthcare providers, employers, research organizations, and AI platforms — rather than replace them.
- G-5 Evolve as an open technical standard that governments, institutions, and software providers can implement independently.

1.3 Non-Goals

- HUGS ID is not a centralized database of personal records. Source data remains with issuing institutions; the framework governs references, proofs, and permissions.
- HUGS ID is not a blockchain or cryptocurrency project. Cryptographic proofs are used for integrity and provenance, not for token economics.
- HUGS ID does not replace legal identity documents, credentials, or institutional records; it defines how those artifacts are verified, referenced, and governed.

2. Problem Statement

2.1 The Fragmentation of Digital Identity

Identity on today's Internet is stored inside thousands of disconnected databases owned by governments, schools, hospitals, employers, sports organizations, financial institutions, and technology companies. Each system holds a partial, unverifiable-from-outside view of a person, and none provides the individual with meaningful authority over how that information flows onward.

2.2 The AI Inflection Point

Artificial intelligence has dramatically accelerated the use of personal information. AI systems can summarize, classify, predict, recommend, and generate new content using data that individuals often neither control nor understand. Traditional identity systems were not designed to answer the questions the AI era now asks:

- Who may use this identity or record, under what authority, and for what purpose?
- Was this artifact created by a human, an institution, or an AI — and can that be proven?
- Which consent covered this specific use, and is it still in force?
- How much trust should a downstream system place in this claim?

HUGS ID addresses these questions by making identity, consent, provenance, and trust first-class, machine-readable objects with defined semantics.

2.3 Design Principles

Identity First — Every digital interaction begins with a verifiable identity. No governed action occurs against an anonymous or unresolved subject.

Data Sovereignty — Individuals retain authority over how verified information about them is governed. Institutional custody of a record does not imply unlimited rights to use it.

Verifiable Provenance — Every trusted record identifies who created it, when it was created, how it was verified, who approved it, and whether it has changed.

AI Accountability — Artificial intelligence must never operate without clearly defined permissions and governance. Every AI action is attributable to an identity, an authorization, a purpose, and a governance policy.

Interoperability — The framework integrates with existing systems rather than replacing them, and is designed for implementation by independent parties.

3. Architecture

3.1 Layered Architecture

The HUGS ID platform consists of independent layers. Each layer performs a specific function, exposes defined interfaces to the layers above and below it, and can be implemented or replaced without invalidating the rest of the stack. Requests flow upward through the stack; verification and trust flow downward.

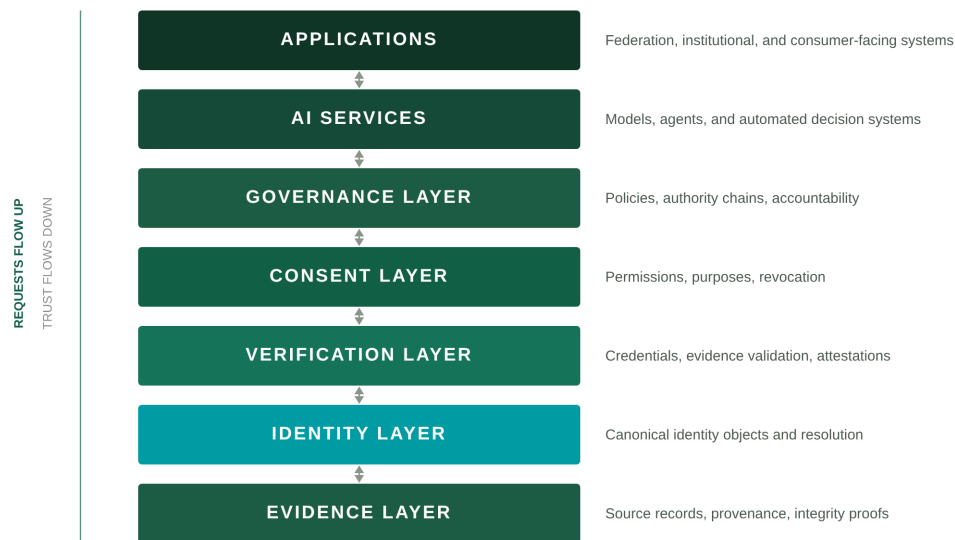


Figure 3-1: The seven-layer HUGS ID architecture. The Identity Layer (teal) anchors the stack.

3.2 Layer Responsibilities

Layer	Responsibility	Primary Objects
Evidence Layer	Source records, provenance metadata, and integrity proofs anchoring all claims.	Evidence Record
Identity Layer	Canonical identity objects, identifier resolution, key binding, and lifecycle management.	Identity Object
Verification Layer	Validation of evidence and issuance of signed, verifiable credentials and attestations.	Verification Object, Credential
Consent Layer	Machine-readable permissions granted by identity controllers, with purpose and revocation semantics.	Consent Object, Guardian Verification

Governance Layer	Policies, signed authority chains, roles, and accountability for every governed action.	Governance Object, Policy, Authority Chain
AI Services	Models, agents, and automated decision systems operating under AI permission classes.	AI Permission Grant, Event Log
Applications	Federation, institutional, and consumer-facing systems consuming the layers below.	—

Table 3-1: Layer responsibilities and primary objects

3.3 Data Flow

1. An application or AI service requests a governed operation against an identity (read, derive, train, generate, distribute, or decide).
2. The Governance Layer evaluates the request against applicable policies and the cryptographic validity of the presented authority chain.
3. The Consent Layer confirms that a valid, unexpired consent covers the requested purpose and action class; for a minor subject, guardian verification is confirmed first (Section 6.5).
4. The Verification Layer confirms that the claims involved meet the required trust level, based on signed Verification Objects.
5. The operation executes atomically with these checks (Section 10.7), and an immutable entry is written to the Event Log binding the action to its identity, authorization, purpose, and policy.

3.4 Governed Domains

The framework defines governed domains — vertical specializations that apply the core layers to a field of practice. Version 1.x specifies Athlete Intelligence in detail (Section 7). Education, healthcare, employment, research, creative works, digital assets, and AI agents are recognized domains; additional domains may be added through future specifications.

4. Identity Layer

4.1 The Canonical Identity Object

DEFINITION — A Canonical Identity Object is the single, authoritative representation of a subject within the HUGS ID framework. It contains no personal records itself; it anchors references, verifications, consents, and governance decisions to one resolvable identifier bound to at least one public key.

Each Canonical Identity Object **MUST** contain the following fields:

Field	Type	Req.	Description
id	URI	MUST	Globally unique HUGS identifier (Section 4.2). Immutable once issued.
type	enum	MUST	individual organization ai-agent digital-asset
controller	URI	MUST	Identifier of the party exercising governance authority over the identity.
status	enum	MUST	Lifecycle state (Section 4.4): pending active suspended revoked retired.
created	date-time	MUST	ISO 8601 UTC timestamp of object creation.
updated	date-time	MUST	Timestamp of the most recent state change.
schema_version	string	MUST	Semantic version of the identity schema the object conforms to.
verification_method	array	MUST (v1.1)	One or more public keys bound to the identity (Section 4.5). Keys MAY be rotated; retired keys are retained for audit.
proof	object	MUST (v1.1)	Integrity proof over the object, signed by the issuing authority's bound key, enabling tamper evidence and origin authentication.

Table 4-1: Canonical Identity Object fields (v1.1)

Personal attributes (name, date of birth, nationality, and similar) are deliberately excluded from the Canonical Identity Object. They remain in institutional source systems and are referenced through verified claims, keeping the identity layer minimal, portable, and privacy-preserving.

4.2 Identifier Scheme

HUGS identifiers are URIs of the form:

```
hugs:id:<type>:<namespace>:<unique-id>
```

Example: hugs:id:individual:us:8f3a9c2e-41d7-4b1e-9c3f-7a2e5d8b6f01. The namespace segment is assigned by the issuing authority within a federation. REQ-4-0 (v1.1): The unique-id MUST be generated with at least 122 bits of randomness (UUIDv4 or a 128-bit CSPRNG value), MUST be collision-resistant, and MUST NOT itself encode personal information. Identifiers resolve through the Identity API (Section 10.3) to the current Canonical Identity Object and its status.

4.3 Identity Types

Type	Subject	Controller
individual	A natural person.	The person, or a verified legal guardian where applicable (Section 6.5).
organization	An institution: federation, school, agency, employer, platform.	The institution's designated governance authority.
ai-agent	An AI system or agent acting under defined permissions (Section 8).	The operating organization; accountability is never waived.
digital-asset	A governed work: media, dataset, credential, creative output.	The rights holder, subject to applicable consents.

Table 4-2: Identity types and their controllers

4.4 Identity Lifecycle

State	Meaning	Permitted transitions
pending	Created, awaiting initial verification.	→ active, → revoked
active	Verified and resolvable; governed operations permitted.	→ suspended, → retired, → revoked
suspended	Temporarily inoperative pending review or dispute.	→ active, → revoked
revoked	Permanently invalidated (e.g., duplicate or fraud). Terminal.	—
retired	Voluntarily closed by the controller. Historical references remain resolvable.	—

Table 4-3: Lifecycle states and permitted transitions

REQ-4-1: An identity in any state other than active MUST NOT be the subject of a new governed operation. REQ-4-2: State transitions MUST be recorded in the Event Log with the acting identity and authority chain.

4.5 Key Binding and Proof of Possession

Version 1.1 binds every HUGS identity to cryptographic keys. Control over an identity is demonstrated by proof of possession of a bound private key, not merely by possession of a bearer token.

REQ-4-3: Every Canonical Identity Object MUST include at least one `verification_method` public key controlled by the identity's controller. Key rotation MUST be supported; retired keys are retained for audit but MUST NOT authorize new operations.

REQ-4-4: Governed operations MUST require proof of possession of a bound key. Conformant mechanisms include signed challenges, DPoP-bound tokens [10], mutual-TLS-bound tokens, or verifiable-credential holder binding [2]. Bearer-token-only authentication is non-conformant for governed operations.

REQ-4-5: The `proof` field is mandatory (MUST) on Canonical Identity Objects, Verification Objects, Guardian Relationship Verification Objects, Authority Chain links, and Event Log entries, in each case signed by the bound key of the issuing or acting party.

4.6 Pairwise Pseudonymous Identifiers

A single persistent, globally resolvable identifier shared with many relying parties would enable cross-party correlation — an unacceptable privacy property, in particular for minors. The canonical identifier is therefore never disclosed directly to relying parties.

REQ-4-6: Relying parties MUST be issued pairwise pseudonymous identifiers: a distinct, non-correlatable subject identifier per (subject, relying-party) pair, derived deterministically and salted, as in OIDC pairwise subject identifiers or peer DIDs [3][5].

REQ-4-7: The mapping between a pairwise identifier and the canonical identifier MUST be held only by the framework's identity service, MUST NOT be exposed through any public API, and MUST be destructible on erasure (Section 6.6).

REQ-4-8: Implementations MUST be threat-modeled against unlinkability for minors: two relying parties, each legitimately holding a pairwise identifier for the same minor, MUST NOT be able to join their records by that identifier.

5. Governance Layer

5.1 Governance Objects

The Governance Layer defines the objects through which authority is expressed and enforced:

- Policy — a machine-readable rule set constraining operations within a domain or institution.
- Authority Chain — a cryptographically signed, ordered sequence of delegations from a root authority to the acting party (Section 5.3).
- Role — a named capability bundle assignable to identities within an institution.
- Decision Record — the auditable outcome of a governance evaluation, stored in the Event Log.

5.2 Policy Model

A Policy binds a scope (domain, institution, or identity set) to constraints. Each Policy **MUST** define:

Field	Description
policy_id	Unique identifier and semantic version of the policy.
issuer	The authority chain of the issuing body (cryptographically verified per Section 5.3).
scope	The identities, data classes, and domains to which the policy applies.
rules	Permitted and prohibited action classes, with conditions (e.g., minimum trust level).
effective / expires	Validity window. Expired policies are retained for audit but not enforced.
supersedes	Optional reference to a prior policy version this policy replaces.
proof	MUST (v1.1). Signature over the policy by the issuing authority's bound key.

Table 5-1: Policy object fields (v1.1)

Where multiple policies apply, the evaluation order is: individual controller policy, then institutional policy, then domain policy, then framework baseline. More specific policies override broader ones; prohibitions always override permissions.

5.3 Authority Chains

DEFINITION — An Authority Chain is a verifiable, ordered sequence of signed delegations — for example: framework → federation → club → registrar — establishing that the acting party's power to perform an operation derives from a recognized root authority. Each link is a signature by the parent over the delegated grant.

Each Authority Chain link **MUST** contain the following fields:

Field	Req.	Description
link_id	MUST	Unique identifier of the delegation link.
parent	MUST	Identifier of the delegating party.
child	MUST	Identifier of the party receiving the delegation.
delegated_scope	MUST	The data classes, domains, and identity sets covered, drawn from the Policy vocabulary.
delegated_actions	MUST	The permitted action classes (Section 8.2), drawn from the Consent vocabulary.
not_before / expires	MUST	Validity window of the delegation.
parent_signature	MUST	Signature by the parent's bound key over (child, delegated_scope, delegated_actions, expiry).

Table 5-2: Authority Chain link fields (v1.1)

The chain as a whole carries `root_key_id` (referencing the framework's published root key set) and a signed `chain_state` (active | suspended | revoked) with a monotonic sequence number for freshness.

REQ-5-1: Every governed operation **MUST** be traceable to a complete authority chain whose every link signature verifies.

REQ-5-2 (attenuation): A delegation cannot exceed the authority of its parent link. The evaluator **MUST** verify that each link's `delegated_scope` and `delegated_actions` are a subset of its parent's; attenuation is permitted, amplification is not.

REQ-5-3: Revoking any link suspends all downstream authority pending re-evaluation. Revocation state **MUST** be signed and carry freshness (sequence or timestamp); evaluators **MUST** confirm current chain state at evaluation time.

REQ-5-4 (v1.1): Chain verification **MUST** reject any chain not rooted at a recognized root key from the framework's published root key set. Root keys **MUST** be rotatable; rotations are published and versioned.

REQ-5-5 (v1.1): Trust level T3 (Certified) is attained only when the attestation's authority chain verifies cryptographically end to end; an unsigned or unverifiable chain cannot produce T3.

5.4 Institutional Roles

Role	Typical capabilities
Registrar	Create and retire identities within the institution's namespace.
Verifier	Validate evidence and issue signed attestations within a defined domain.
Governance Officer	Issue and amend policies; adjudicate disputes.

Data Custodian	Operate source systems referenced by evidence records.
Auditor	Read-only access to Event Logs and decision records.

Table 5-3: Reference institutional roles (extensible by policy)

6. Consent Layer

6.1 The Consent Object

DEFINITION — A Consent Object is a machine-readable record of a permission granted by the controller of an identity to a specified grantee, for a specified purpose, over a specified scope of verified information, for a defined period.

Field	Req.	Description
consent_id	MUST	Unique identifier of the consent.
subject	MUST	The identity to which the consented information pertains.
grantor	MUST	The identity (controller or authorized delegate) granting the consent; for a minor subject, a guardian verified per Section 6.5.
grantee	MUST	The identity (institution, application, or AI agent) receiving the permission.
purpose	MUST	A term from the Purpose Taxonomy (Section 6.2).
scope	MUST	The data classes or specific claims covered by the consent.
actions	MUST	Permitted action classes (Section 8.2), e.g., read, derive, generate.
conditions	SHOULD	Additional constraints: minimum trust level, retention limits, redistribution terms.
redistribution / sublicense	MUST for media-licensing (v1.1)	Whether the grantee may redistribute or sublicense the consented material, and on what terms.
downstream_revocation	MUST for media-licensing (v1.1)	How revocation propagates to already-distributed copies and sublicensees: notice obligations, takedown windows, and permitted archival exceptions.
granted / expires	MUST	Validity window. Expired consents are inoperative.
revoked	MUST	Revocation timestamp and reason, where applicable.
proof	MUST (v1.1)	Signature by the grantor's bound key over the consent's material fields.

Table 6-1: Consent Object fields (v1.1)

6.2 Purpose Taxonomy

Consent purposes are drawn from a controlled vocabulary so that both humans and machines interpret permissions identically. The v1.x taxonomy includes:

- eligibility-verification — confirming status, age, registration, or qualification.
- performance-analysis — computing metrics and insights over verified records.
- selection-evaluation — informing recruitment, admission, or selection decisions.
- media-licensing — use of identity-linked media or likeness under license.
- research — inclusion in anonymized or pseudonymized research datasets.
- model-training — use of verified information in AI training or fine-tuning (Section 8).

Domain specifications MAY extend the taxonomy; extensions MUST namespace custom purposes (e.g., `athletics:transfer-clearance`).

6.3 Consent Lifecycle

A consent moves through the states `granted` → `active` → (`expired` | `revoked` | `superseded`). A grantee MUST verify consent state at the time of each use; caching a consent evaluation beyond its stated conditions is non-conformant. Evaluation and use MUST be atomic or fail closed (Section 10.7).

6.4 Revocation

Revocation is a first-class operation, not an exceptional one:

1. The controller revokes a consent through the Consent API; the object records the timestamp and reason.
2. The revocation propagates to the Event Log and to all registered webhooks of affected grantees (Section 10.5), within a bounded, auditable propagation window (Section 10.7).
3. Downstream systems MUST cease new uses immediately and honor the consent's `downstream_revocation` and retention conditions for already-distributed or derived artifacts, as defined by the consent's conditions and applicable policy.

REQ-6-1: Consent MUST be as easy to withdraw as it was to grant. REQ-6-2: A use that continues after effective revocation MUST be detectable from the Event Log and attributable to the acting identity.

6.5 Guardian Relationship Verification

Where the subject of a consent is a minor, the grantor's authority cannot be merely asserted; it MUST be independently verified before the consent becomes effective.

DEFINITION — A Guardian Relationship Verification Object (GRV) is a signed attestation, issued by a competent authority, establishing that a specified guardian holds legal authority over a specified minor's

identity.

Field	Req.	Description
grv_id	MUST	Unique identifier of the verification.
minor	MUST	The subject identity (an individual whose age band is minor).
guardian	MUST	The guardian identity being verified.
verifying_authority	MUST	The competent authority issuing the attestation (e.g., civil registry, court, federation registrar acting under its mandate).
method	MUST	The verification method applied (documentary, registry lookup, in-person, eIDAS-style eID, etc.).
evidence_ref	SHOULD	Reference to the Evidence Record(s) supporting the verification.
issued / expires	MUST	Validity window of the verification.
proof	MUST	Signature by the verifying authority's bound key.

Table 6-2: Guardian Relationship Verification Object fields (v1.1)

REQ-6-3: A consent whose subject is a minor **MUST NOT** become effective until a valid GRV, issued by a competent authority and bound into the subject's record, establishes the grantor's guardianship. This is the framework's mechanism for verifiable parental consent under COPPA and GDPR Article 8.

REQ-6-4: GRV validity **MUST** be re-evaluated when the underlying authority record changes or the GRV expires.

REQ-6-5: Revocation or expiry of a GRV **MUST** suspend all consents that depend on it, pending revalidation or replacement by another verified guardian.

6.6 Sensitive Data and Erasure

Certain data classes — including biometric, physiological, and development data concerning minors (Section 7.2) — are elevated to a sensitive class.

REQ-6-6: Sensitive-class data **MUST** require express, separately granted consent; where the subject is a minor, that consent **MUST** be guardian-verified per Section 6.5 and **MUST** be independently revocable.

REQ-6-7 (erasure-compatible audit): The immutable Event Log **MUST** anchor only non-personal references — pairwise identifiers (Section 4.6) and salted hashes. The mapping between those references and personal data **MUST** be destructible, so that exercising the right to erasure renders log entries permanently unlinkable without modifying the log itself. Immutability of the audit trail and the right to erasure are both satisfied by construction.

7. Athlete Intelligence

7.1 Overview

Athlete Intelligence is the first governed domain specified under the HUGS ID framework. It applies the Identity, Verification, Consent, Governance, and Trust layers to sport — a field where identity, age, eligibility, performance history, and media rights carry high value and are routinely mishandled across clubs, schools, federations, agents, and platforms.

The domain gives an athlete a single canonical identity that persists across teams, schools, leagues, and countries — presented to relying parties only through pairwise identifiers (Section 4.6) — while every claim attached to that identity — a registration, a result, a clearance, a highlight — carries verifiable provenance and a governing consent. Because many athletes are minors, the safeguards of Sections 4.6, 6.5, 6.6, and 8.4 apply to this domain without exception.

7.2 Governed Data Classes

Data class	Contents	Typical issuers
identity-registration	Verified identity, age band, registration status, federation membership.	Federations, clubs, schools
eligibility	Clearances, transfer status, amateur/professional standing, disciplinary records.	Federations, governing bodies
performance	Verified results, statistics, rankings, and milestones with provenance.	Event organizers, leagues, timing providers
development	Training benchmarks, combine results, academic standing where linked to eligibility. SENSITIVE CLASS (Section 6.6).	Academies, schools, testing bodies
media-rights	Identity-linked media, likeness usage, licensing terms.	Athlete (controller), media partners

Table 7-1: Athlete Intelligence governed data classes

The development data class comprises biometric and physiological data concerning athletes who are frequently minors. It is elevated to the sensitive class defined in Section 6.6: express, separately granted, guardian-verified, independently revocable consent is required before any governed operation over it.

Health-adjacent information is out of scope for v1.x and will be addressed in coordination with the healthcare domain specification.

7.3 Use Cases

- Eligibility verification — a federation confirms age band and registration in seconds against verified claims rather than documents of unknown provenance.
- Transfer and clearance — a signed authority chain from federation to club to registrar makes a clearance decision auditable end to end (Section 5.3).
- Recruitment evaluation — scouts and programs consume verified performance histories under a selection-evaluation consent granted by the athlete or verified guardian.
- Media and likeness licensing — broadcasters and platforms operate under media-licensing consents carrying explicit redistribution and downstream-revocation terms (Section 6.1).
- AI-assisted scouting — models access athlete data only under AI permission classes (Section 8), with every inference attributable, signed, and logged, and any decide-class action subject to enforced human review (Section 8.4).

8. AI Permissions

8.1 AI Agent Identity

Every AI system that reads, derives from, trains on, generates about, distributes, or decides over governed information **MUST** hold an identity of type ai-agent (Section 4.3) with at least one bound key (Section 4.5). An AI agent's controller is the operating organization; accountability for an agent's actions always resolves to a legal person or institution. Anonymous or unattributed AI operation against governed data is non-conformant.

8.2 AI Permission Classes

Class	Operation	Baseline requirement
read	Access verified data as context for inference.	Valid consent covering the purpose; active identity; proof of possession.
derive	Produce summaries, scores, or insights from verified data.	read + derive action in consent; output inherits provenance.
train	Use verified data in model training or fine-tuning.	Explicit model-training purpose; retention conditions honored.
generate	Create new content that references or depicts an identity.	generate action in consent; synthetic output MUST carry bound provenance (Section 8.5).
distribute	Publish or transmit derived or generated artifacts.	Distribution terms in consent conditions; downstream labeling preserved.
decide	Take an automated action affecting the subject (selection, eligibility, pricing).	Explicit policy authorizing the decision class; minimum trust level T3; enforced human review per Section 8.4.

Table 8-1: AI permission classes and baseline requirements

8.3 Attribution Requirements

Every AI action within the framework **MUST** be attributable to four elements, recorded in the Event Log at execution time:

1. an identity — the ai-agent identity performing the action;
2. an authorization — the consent and permission classes relied upon;
3. a purpose — the taxonomy term the action serves;
4. a governance policy — the policy and authority chain under which the agent operates.

REQ-8-1: AI-generated content that references an identity **MUST** carry machine-readable provenance identifying it as generated, its source claims, and its permission basis. REQ-8-2: Permission evaluations

MUST occur at the time of use; pre-computed or blanket authorizations are non-conformant. A standing consent is not a blanket authorization: it remains scoped to named purposes, action classes, and conditions, and is re-evaluated atomically at each use (Section 10.7).

REQ-8-3: The four-element attribution record MUST be signed by the acting agent's bound key. Self-reported, unsigned attribution is non-conformant; attribution that cannot be verified against the agent's registered key MUST be treated as an unattributed action.

8.4 Enforced Human Review and Contestation

Documentary safeguards are insufficient for automated decisions. Where a decide-class action affects a subject — and mandatorily where the subject is a minor — human review is an enforced control, not a documented option.

REQ-8-4: For every decide-class action affecting a subject, a qualified human reviewer MUST exercise review before the decision takes effect. The review MUST produce a Decision Record in the Event Log capturing, at minimum:

Field	Req.	Description
decision_id	MUST	Unique identifier of the decide-class action under review.
subject	MUST	The affected identity (recorded as a pairwise reference, Section 6.6).
agent	MUST	The ai-agent identity whose action is under review.
reviewer	MUST	The reviewing human's identity, bound to a key and signed.
disposition	MUST	Confirmed, modified, or overturned, with a stated basis.
timestamp	MUST	When the review was exercised.

Table 8-2: Decision Record fields (v1.1)

REQ-8-5: The subject — or, for a minor, the verified guardian — MUST be notified of the decision and the review outcome, and MUST be offered a contestation path with defined response timelines. A contested decision is suspended pending re-review.

A human review path that is defined but never invoked is explicitly non-conformant. Conformance assessment for decide-class operation includes auditing Decision Records against executed decide-class actions; a gap between the two is a conformance failure.

8.5 Synthetic Media Provenance

Synthetic-media labeling protects subjects only if the label survives distribution. A label that can be stripped without detection is no defense against impersonation or deepfakes.

REQ-8-6: Synthetic or AI-generated content that references or depicts a governed identity MUST carry provenance cryptographically bound to the content itself, using a tamper-evident content credential mechanism such as C2PA Content Credentials [9]. The credential MUST reference the generating agent's

identity and permission basis (Section 8.3). Content whose bound credential is missing, invalid, or inconsistent with its recorded history **MUST** be treated as unverified, and platforms within the framework **SHOULD** so indicate.

8.6 Prohibited Uses

- Training on identity-linked data without an explicit model-training consent.
- Generating synthetic media of an identifiable person without a generate-class consent and cryptographically bound labeling.
- Automated decisions in the decide class without an authorizing policy, T3 trust minimum, and exercised human review per Section 8.4.
- Circumventing revocation by retaining or re-deriving artifacts whose retention conditions have lapsed; re-derivation after revocation is detectable through the signed attribution record (REQ-8-3) and provenance chain (REQ-8-6) and is non-conformant.
- Operating an AI agent without a resolvable identity, a bound key, and an accountable controller.

9. Trust Framework

9.1 The Trust Score

DEFINITION — A Trust Score is a computed assessment of how much confidence a relying party should place in a claim, an identity, or an artifact. It is evidence-based, purpose-relative, and recomputed as underlying evidence, verification, and dispute state change.

A Trust Score is derived from five components:

- Verification depth — how many independent, authoritative sources confirm the claim, where independence means distinct root authorities (Section 9.3).
- Provenance completeness — whether the full provenance record (creator, timestamp, verification method, approver, change history) is intact.
- Authority weight — the standing of the attesting institution within the relevant authority chain.
- Recency — the age of the evidence relative to the claim's expected validity window.
- Dispute state — whether the claim is uncontested, under review, or previously corrected.

9.2 Trust Levels

Level	Name	Basis
T0	Unverified	Self-asserted only; no supporting evidence. Usable for display, never for decisions.
T1	Basic	Single-source verification from a recognized custodian, cryptographically signed.
T2	Verified	Multi-source or institutional verification with complete provenance; sources are distinct root authorities.
T3	Certified	Attested by the governing body through a complete, cryptographically verified authority chain (Section 5.3). Required for decide-class AI actions.
T4	Canonical	Continuously verified, full provenance, uncontested over time. The reference state for high-stakes operations.

Table 9-1: Trust levels

Policies declare minimum trust levels per action class; the Governance Layer enforces them at evaluation time. A score is always scoped to a claim and a purpose — there is no universal “trusted person” flag in the framework.

9.3 Verification Framework

Verification converts evidence into attestations. The Verification Layer consumes Evidence Records — source documents, registry entries, event feeds — and issues Verification Objects recording what was verified, by whom, against which method, and when. Verification Objects are the inputs from which trust levels are computed; they are versioned and revocable, and revocation of an underlying verification MUST trigger recomputation of dependent scores within the bounded propagation window defined in Section 10.7.

In v1.1, every Verification Object MUST be signed by the verifying party's bound key (Section 4.5), and every Evidence Record MUST carry integrity protection binding it to its source. An unsigned attestation is not a verification and MUST NOT contribute to any trust computation. For the purpose of verification depth, “independent sources” means attestations rooted in distinct recognized root authorities; multiple attestations from a single actor or a single root count as one source.

9.4 Reputation Framework (Planned)

Version 2.0 will introduce a Reputation Framework: longitudinal, behavior-based standing for institutions, verifiers, and AI agents — distinct from the per-claim Trust Score. Reputation models are explicitly deferred from the v1.x line to keep the trust framework evidence-based and auditable.

9.5 Regulatory Alignment and Trust Chain

HUGS ID is designed around a fundamental principle:

Trust in artificial intelligence depends on trusted identity, verifiable provenance, and an unbroken chain of custody.

As governments and regulators introduce requirements for AI-generated content to include provenance metadata and verification mechanisms, HUGS ID provides a complementary trust framework. While provenance can indicate how digital content was created, HUGS ID extends that capability by helping establish who created it, who verified it, how it has changed over time, and whether it remains authentic.

The HUGS ID Trust Chain is built on five core pillars:

- Verified Identity — Establish the trusted identity of the creator, organization, athlete, or institution.
- Verified Provenance — Preserve standardized provenance metadata describing how, when, and with what tools digital content was created, including AI-assisted generation where applicable.
- Chain of Custody — Maintain an auditable record of significant events throughout the lifecycle of the asset, including creation, edits, approvals, transfers, publication, and revocation.

- Integrity Verification — Enable any recipient to independently verify that digital content remains consistent with its documented history and has not been altered outside the recorded chain of custody.
- Transparent Attribution — Provide clear, verifiable information regarding authorship, ownership, licensing, permissions, and AI involvement.

Together, these five pillars establish a Digital Trust Chain that extends beyond watermarking or embedded metadata alone. Rather than simply indicating that content was generated by AI, HUGS ID links digital assets to verified people, organizations, permissions, and lifecycle events. This creates a transparent and auditable framework for authenticity, accountability, and trust across sports, entertainment, education, government, and enterprise ecosystems.

The platform is intended to evolve alongside emerging standards for AI transparency, provenance, and responsible use while remaining interoperable with future regulatory and industry frameworks.

This formulation establishes an architectural foundation for HUGS ID — shifting the industry narrative from passive AI detection to proactive, lifecycle-wide accountability.

10. APIs

10.1 Overview

HUGS ID exposes a versioned REST API over HTTPS. All resources are namespaced under `/v1/`; object representations are JSON and conform to the published v1 schemas. API behavior follows the same governance rules as the rest of the framework — the API is an enforcement surface, not a bypass.

10.2 Authentication and Authorization Scope

Machine clients authenticate with OAuth 2.0 client credentials [4]; user-facing flows use OpenID Connect [5]. Tokens **MUST** be sender-constrained by proof of possession (DPoP [10] or mutual TLS) so that a leaked or replayed token does not impersonate an identity; bearer-possession-only credentials are non-conformant for governed operations. Tokens carry the caller's identity and authority context, which are evaluated on every request.

DEFINITION — Authorization scope is the set of object references, purposes, and action classes for which the caller holds a currently valid grant — by consent, policy, or authority chain — evaluated at request time against the specific object(s) addressed by the request.

REQ-10-1: API credentials are issued per identity and role; shared or anonymous credentials are non-conformant.

REQ-10-2: Every read, search, and publish operation **MUST** enforce object-level authorization: the response **MUST** contain only objects for which the caller holds a valid grant, and list and search endpoints **MUST NOT** reveal the existence of objects outside the caller's scope. Publication of governance objects (for example `POST /v1/governance/policies`) **MUST** be authorized against the caller's verified authority chain at the scope being published.

10.3 Core Resources

Resource	Methods	Purpose
<code>/v1/identities</code>	GET, POST	Resolve, search, and register Canonical Identity Objects. Resolution returns pairwise references only (Section 4.6).
<code>/v1/identities/{id}</code>	GET	Retrieve the current object and lifecycle state of an identity.
<code>/v1/identities/{id}/verifications</code>	GET	List verifications and attestations attached to an identity.
<code>/v1/consents</code>	GET, POST	Grant consents; list consents by subject, grantor,

		or grantee.
/v1/consents/{id}/revoke	POST	Revoke a consent with a reason; propagates to the Event Log and webhooks.
/v1/governance/policies	GET, POST	Publish and query policies within the caller's verified authority scope.
/v1/trust/scores/{identityId}	GET	Retrieve claim-level trust scores with component breakdown.
/v1/events	GET	Query the Event Log (audit stream) within the caller's authorization scope (REQ-10-2).

Table 10-1: Core API resources (v1)

10.4 Status Codes

Code	Meaning
200 OK	Request succeeded.
201 Created	Object created (identity registered, consent granted, policy published).
400 invalid_request	Malformed request or schema validation failure.
401 unauthorized	Missing or invalid credentials.
403 forbidden	The request is not permitted — by consent, policy, trust level, or scope. Security-sensitive denial reasons are deliberately not distinguished (see below).
404 not_found	Identifier does not resolve within the caller's authorization scope.
409 version_conflict	Object has changed since the caller's version; re-read and retry.
410 revoked	Target object (identity, consent, verification) has been revoked.
429 rate_limited	Request quota exceeded.

Table 10-2: Standard status codes (v1.1)

Denial responses are uniform by design: distinguishing `consent_denied` from `policy_denied` from `trust_insufficient` would let an unauthorized caller infer the existence and protection state of objects it cannot see. Denial detail is recorded in the Event Log, visible to parties whose scope covers it.

10.5 Events and Webhooks

Every governed action emits an event to the Event Log. Subscribers register webhooks for event types including: `identity.created`, `identity.updated`, `identity.state_changed`, `consent.granted`, `consent.revoked`, `verification.issued`, `verification.revoked`, `trust.changed`, `policy.updated`, and `ai.action_executed`. Webhook payloads are signed so receivers can verify framework origin (Section 10.6). Event payloads contain pairwise references and non-personal metadata only, in accordance with Section 6.6.

10.6 Webhook Security

Outbound webhooks turn the framework's delivery agent into a client of subscriber-chosen URLs; without constraints this is a server-side request forgery and exfiltration surface.

REQ-10-3 (delivery safety): Callback URLs MUST use https, MUST resolve to public, non-reserved IP addresses (loopback, RFC 1918, link-local, and cloud metadata ranges are rejected), and MUST be re-validated against the pinned address at delivery time to resist DNS rebinding. Deliveries MUST originate from an egress-restricted network path carrying no ambient credentials.

REQ-10-4 (payload signatures): Webhook payloads MUST be signed using a fully specified signature suite — Ed25519 by default — with published verification keys, defined key rotation, and replay protection via timestamp plus nonce. Receivers MUST verify the signature, timestamp freshness, and nonce before acting on a payload.

10.7 Atomicity and Fail-Closed Enforcement

Governance checks that are separated in time from the operations they authorize can be raced: a consent, verification, or identity status can change between check and use.

REQ-10-5: The evaluation of consent, policy, trust level, and identity status for a governed operation MUST be atomic with the operation itself; where atomicity is not achievable, the operation MUST fail closed while any dependency is pending re-evaluation.

REQ-10-6: Revocation of a consent, verification, identity, or authority-chain link MUST propagate to all enforcement points within a bounded, published, auditable time window. Until propagation completes, affected enforcement points MUST fail closed for the revoked grant.

11. Roadmap

11.1 Release Roadmap

Release	Scope
Version 1.0	Identity Framework; Governance Framework; Consent Framework; Verification Model; Athlete Intelligence domain; Trust Chain (five pillars).
Version 1.1 (this document)	Security Review remediations as normative requirements: signed Authority Chains; key binding and proof of possession; Guardian Relationship Verification; enforced human review and contestation; synthetic-media provenance binding; pairwise identifiers and erasure-compatible audit; object-level API authorization; webhook security; atomic fail-closed enforcement; identifier entropy.
Version 2.0	AI Agent Governance (full agent lifecycle); Cross-Domain Trust Exchange; Distributed Verification; Institutional Federation; Advanced Reputation Models.
Version 3.0	Global Identity Federation; Autonomous AI Governance; Real-Time Compliance Engine; Decentralized Trust Networks.

Table 11-1: Release roadmap

11.2 Versioning Policy

Every specification and schema follows semantic versioning (MAJOR.MINOR.PATCH). MAJOR releases may change object semantics; MINOR releases add backward-compatible capabilities; PATCH releases are editorial. Backward-compatibility requirements are defined for every release: within a major line, consumers written against v1.0 MUST continue to operate against all v1.x schemas without modification. Version 1.1 honors this policy: every v1.1 requirement strengthens an existing field or adds a new one; no v1.0 field was removed or redefined. Requirement identifiers are stable across v1.x revisions.

11.3 Contributing

HUGS ID welcomes contributions from developers, researchers, academic institutions, governing bodies, standards organizations, and industry partners. Independent implementations are encouraged, provided they conform to the published specifications. Future versions will evolve through public review and collaborative implementation; comments and implementation reports should be submitted through the documentation portal.

12. Security Review Disposition

12.1 Review Outcome

An independent security and architecture review of the v1.0 Public Working Draft was completed prior to this revision. The review was a multi-stage automated audit, subsequently hand-vetted and clustered by root cause; its findings survived an adversarial validation pass in which candidate findings were actively challenged and a number were rejected as already addressed. The complete review text is retained, unedited, in the companion document HUGS ID Security Review and Remediation Annex v1.0.

The review's central finding is accepted as accurate: the v1.0 architecture is sound and unusually mature for a working draft — clean layer separation, first-class consent and revocation, an explicit AI-permission model, and graduated trust levels — but the specification stated its security goals without yet defining the cryptographic machinery and enforcement requirements that make those goals true. Nearly every finding was a missing mechanism, not a structural mistake.

This is a strong, credible security review, and this revision treats it as a punch-list rather than a critique: every finding that survived the review's own adversarial validation has been dispositioned, and the remedies are incorporated directly into this specification as normative requirements.

12.2 Prerequisites to Production Implementation

The review's five highest-priority remedies are adopted as prerequisites: no production implementation of HUGS ID — particularly in domains governing minors — should proceed until the corresponding requirements of this revision are implemented:

1. Signed Authority Chain objects. Each delegation link is a signature by the parent over the child identity, delegated scope, delegated actions, and expiry; chains are rooted at published, rotatable root keys, enforce attenuation, and carry signed revocation state (Section 5.3).
2. Key binding. Every HUGS ID, Verification Object, Evidence Record, and AI action is bound to verifiable keys, with proof of possession required for governed operations (Sections 4.1, 4.5, 8.3, 9.3, 10.2).
3. Guardian Relationship Verification. A GRV issued by a competent authority **MUST** be validated before any consent concerning a minor becomes effective (Section 6.5).
4. Enforced AI safeguards. Decide-class AI actions affecting a subject — mandatorily for minors — require exercised human review with logged Decision Records, subject or guardian notification, and a contestation path (Section 8.4).
5. Privacy engineering for minors. Pairwise pseudonymous identifiers, elevated protection for biometric and development data, and an erasure-compatible audit-log design (Sections 4.6, 6.6).

The review's remaining findings are likewise formalized in this revision: object-level API authorization (Section 10.2); SSRF-safe webhook delivery and fully specified payload signatures (Section 10.6); atomic, fail-closed consent and revocation enforcement (Section 10.7); minimum identifier entropy (Section 4.2);

downstream media-rights revocation semantics (Section 6.1); and cryptographically bound synthetic-media provenance (Section 8.5).

12.3 Remediation Mapping

Review theme	Severity	Disposition in v1.1
1. Authority chains have no cryptographic construction	Critical	Section 5.3: signed chain-link object, root keys, attenuation, expiry, signed revocation; REQ-5-1 through REQ-5-5.
2. Nothing is bound to a key	High	Sections 4.1, 4.5, 9.3, 10.2: key-bound identities and objects, proof of possession; proof elevated to MUST.
3. Guardianship over a minor is asserted, never verified	High	Section 6.5: Guardian Relationship Verification Object; REQ-6-3 through REQ-6-5.
4. AI-permission safeguards are documentary, not enforced	High	Sections 8.2–8.5: enforced review, Decision Records, notification and contestation, signed attribution, bound synthetic-media provenance.
5. Privacy doesn't hold for minors	High	Sections 4.6, 6.6: pairwise identifiers, sensitive data class, erasure-compatible audit log.
6. API authorization scope undefined	High	Section 10.2: normative scope definition and object-level authorization; REQ-10-2.
7. Webhook delivery is an SSRF and exfiltration surface	High	Section 10.6: delivery safety and signature suite; REQ-10-3, REQ-10-4.
8. No atomicity or fail-closed default	High	Section 10.7: atomic evaluation, fail-closed default, bounded propagation; REQ-10-5, REQ-10-6.
9. Identifier entropy underspecified	Medium	Section 4.2: minimum 122-bit entropy; normative example corrected; REQ-4-0.
10. Media-rights consent semantics gap	High	Section 6.1: redistribution, sublicense, and downstream-revocation fields on the Consent Object.

Table 12-1: Mapping of review themes to v1.1 dispositions

The review's stated limits are acknowledged: it assessed the specification text, not a running implementation, and several of its remedies — such as egress restriction and status-code uniformity — are mandated here but ultimately enforced in code. A data protection impact assessment and privacy counsel review remain required before production implementation, as they were before this revision.

13. References

Normative References

- [1] S. Bradner, “Key words for use in RFCs to Indicate Requirement Levels,” BCP 14, RFC 2119, IETF, March 1997. <https://www.rfc-editor.org/rfc/rfc2119>

Informative References

- [2] W3C, “Verifiable Credentials Data Model v2.0,” W3C Recommendation. <https://www.w3.org/TR/vc-data-model-2.0/>
- [3] W3C, “Decentralized Identifiers (DIDs) v1.0,” W3C Recommendation. <https://www.w3.org/TR/did-core/>
- [4] D. Hardt (Ed.), “The OAuth 2.0 Authorization Framework,” RFC 6749, IETF, October 2012. <https://www.rfc-editor.org/rfc/rfc6749>
- [5] OpenID Foundation, “OpenID Connect Core 1.0.” https://openid.net/specs/openid-connect-core-1_0.html
- [6] ISO/IEC 27001, “Information security management systems — Requirements.”
- [7] NIST Special Publication 800-63, “Digital Identity Guidelines.”
- [8] Regulation (EU) 2016/679 (General Data Protection Regulation).
- [9] Coalition for Content Provenance and Authenticity (C2PA), “C2PA Technical Specification — Content Credentials.” <https://c2pa.org/specifications/>
- [10] D. Fett, B. Campbell, J. Bradley, T. Lodderstedt, M. Jones, D. Waite, “OAuth 2.0 Demonstrating Proof of Possession (DPoP),” RFC 9449, IETF, September 2023. <https://www.rfc-editor.org/rfc/rfc9449>

These references inform the design of HUGS ID. Where this specification and a referenced standard conflict, this specification defines behavior within the HUGS ID framework only and does not modify the referenced standard.



Technical Specification · Version 1.1 · Public Working Draft

hugsid.com · learn.xpguess.com

© 2026 HUGS ID™. This specification is published as a public working draft for review and implementation.

